

Vulnerability Report – SauceDemo Security Testing

DevelopersHubCorporation Internship | Domain: Software Quality Assurance (SQA)

Intern: Esha Tabbassum | ID: DHC-1019 | Date: March 19, 2026, |Tool Used: OWASP ZAP 2.17.0 |Target: <https://www.saucedemo.com/>

Executive Summary

A security assessment was performed on the SauceDemo web application using OWASP ZAP. The scan identified **12 security-related findings**, categorized as **4 Medium**, **4 Low**, and **4 Informational** issues. No High-risk vulnerabilities were detected. The findings primarily relate to missing security headers, CORS misconfiguration, and information disclosure.

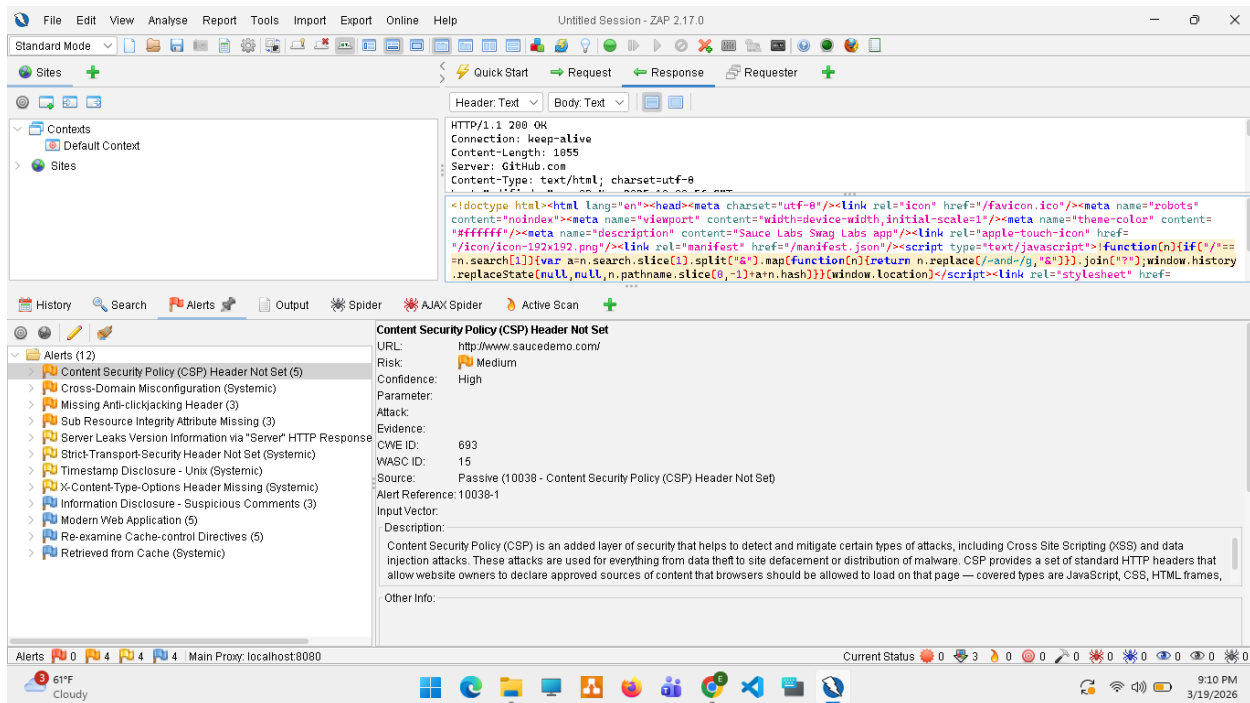
Risk Summary

Risk Level	Count
High	0
Medium	4
Low	4
Informational	4
Total	12

MEDIUM RISK FINDINGS (4)

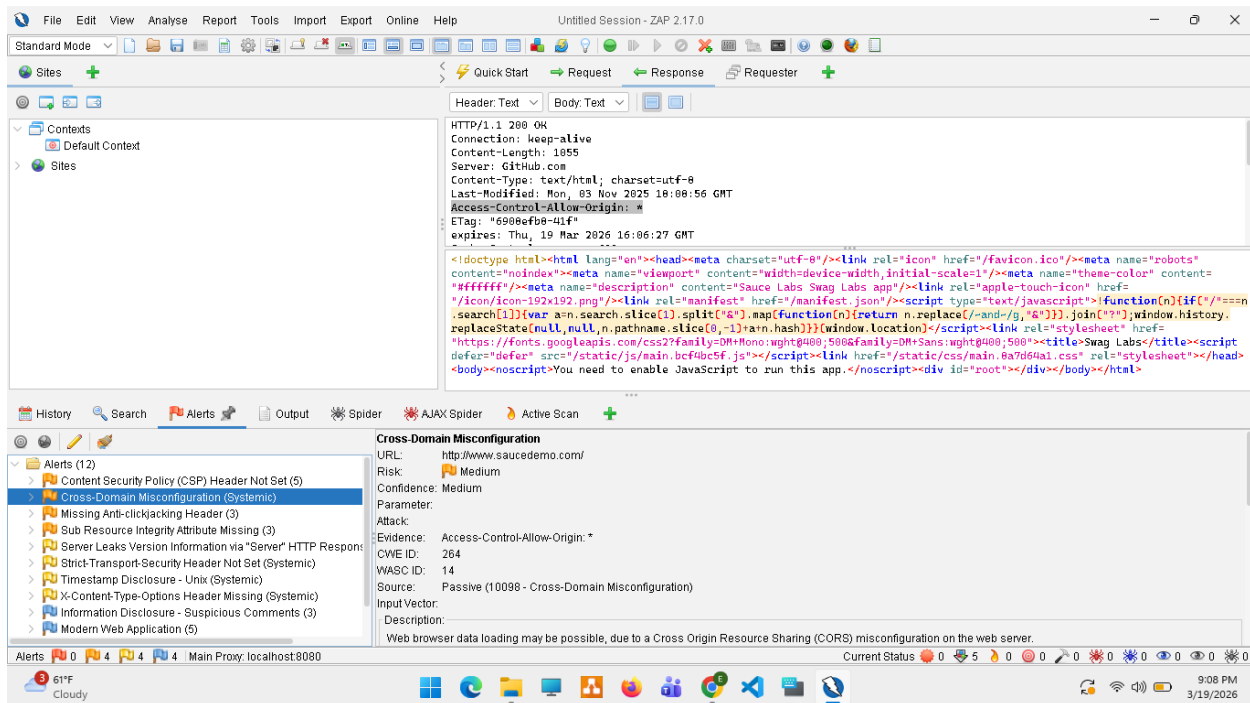
Finding M1: Content Security Policy (CSP) Header Not Set

Field	Details
Risk Level	Medium
Confidence	High
Description	Content Security Policy (CSP) helps prevent XSS attacks by specifying approved sources of content that browsers should be allowed to load.
URL	https://www.saucedemo.com/
Evidence	CWE ID: 693, WASC ID: 15
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.



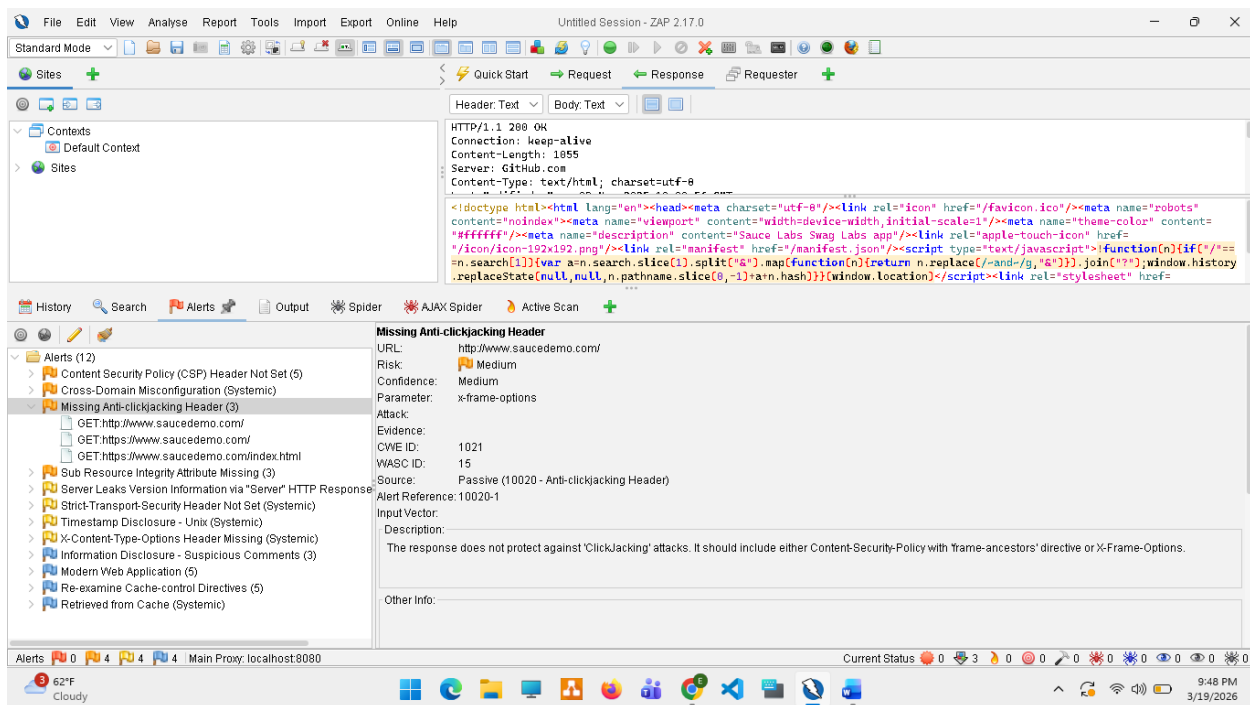
Finding M2: Cross-Domain Misconfiguration

Field	Details
Risk Level	Medium
Confidence	Medium
Description	CORS misconfiguration allows cross-domain requests. The `Access-Control-Allow-Origin: *` header permits any website to access resources.
URL	https://www.saucedemo.com/
Evidence	Access-Control-Allow-Origin: *
Solution	Restrict CORS policy to trusted domains only.



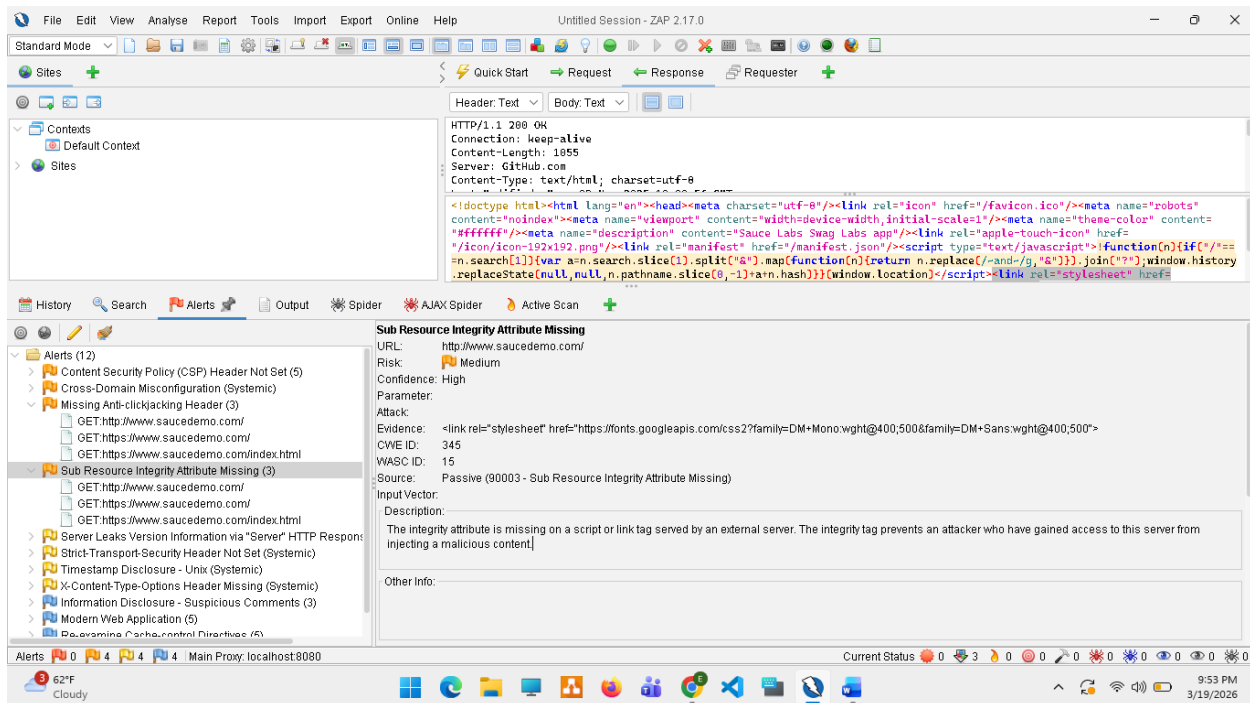
Finding M3: Missing Anti-clickjacking Header

Field	Details
Risk Level	Medium
Confidence	Medium
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	https://www.saucedemo.com/
Evidence	'Access-Control-Allow-Origin: *' header present
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.



Finding M4: Sub Resource Integrity Attribute Missing

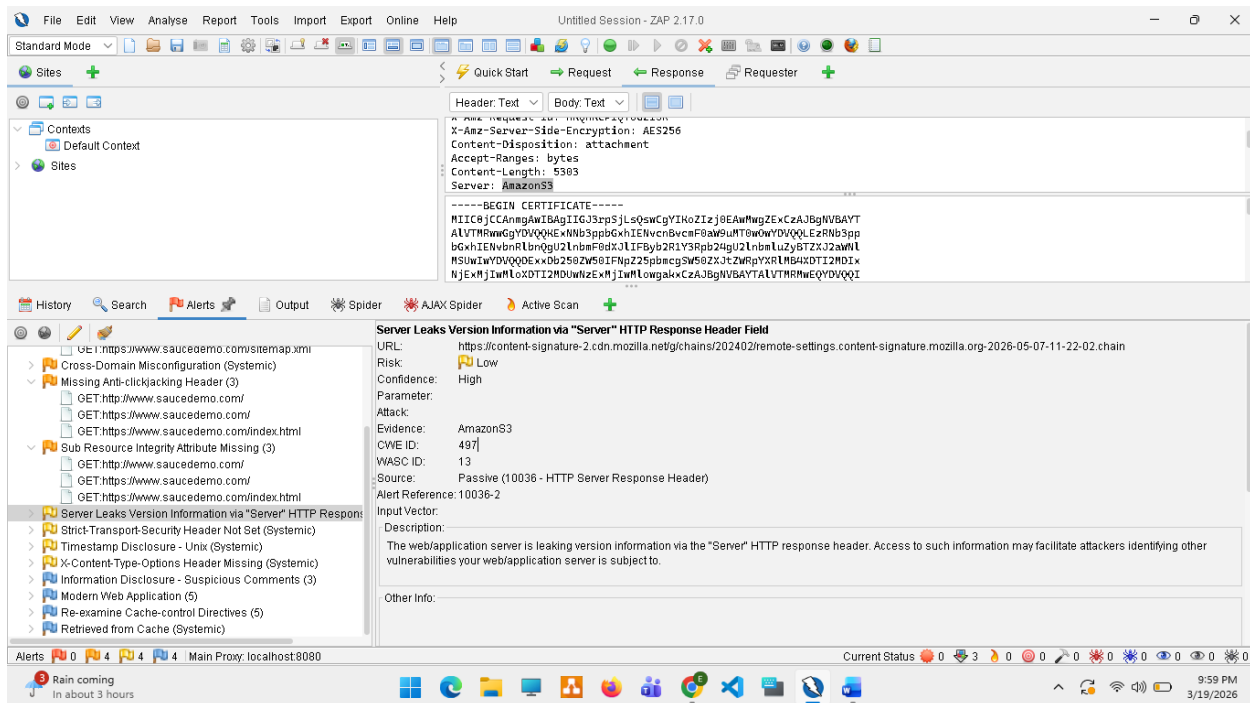
Field	Details
Risk Level	Medium
Confidence	High
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting malicious content.
URL	https://www.saucedemo.com/
Evidence	<linkrel="stylesheet"href="https://fonts.googleapis.com/css2?family=DM+Mono:wght@400;500&family=DM+Sans:wght@400;500">
Solution	Provide a valid integrity attribute to the tag.



● LOW RISK FINDINGS (4)

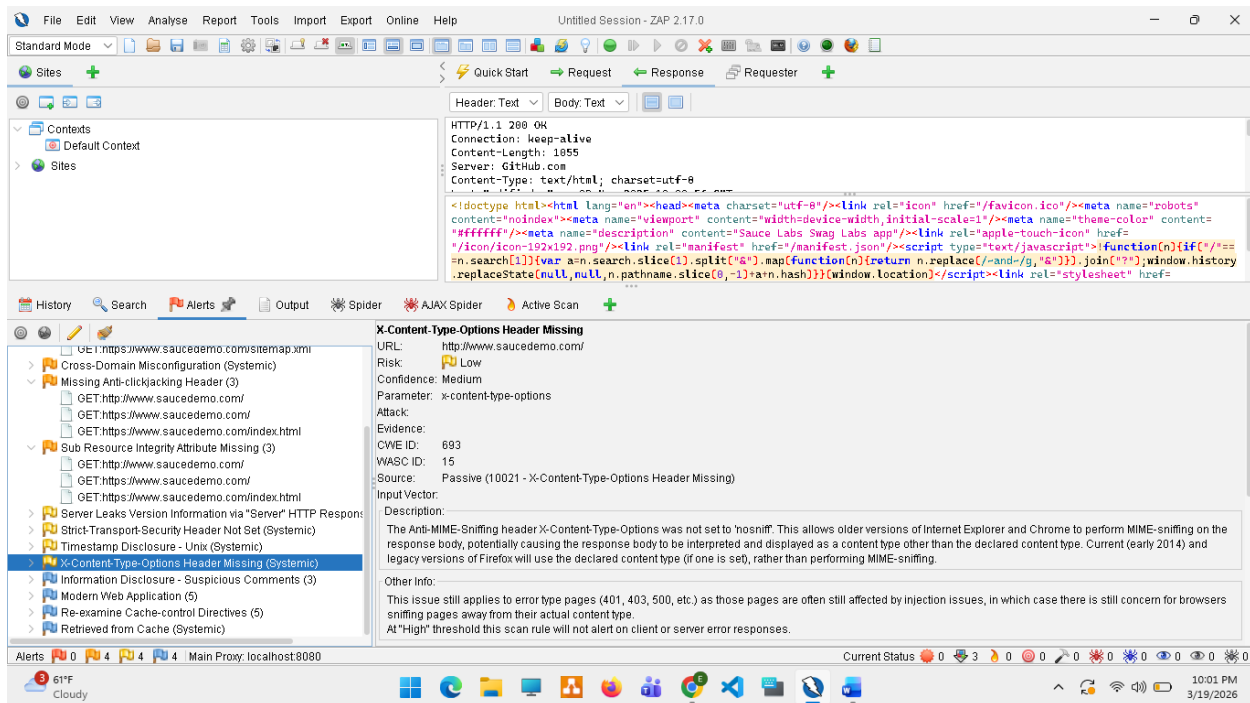
Finding L1: Server Leaks Version Information

Field	Details
Risk Level	Low
Confidence	High
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	https://www.saucedemo.com/
Evidence	AmazonS3
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.



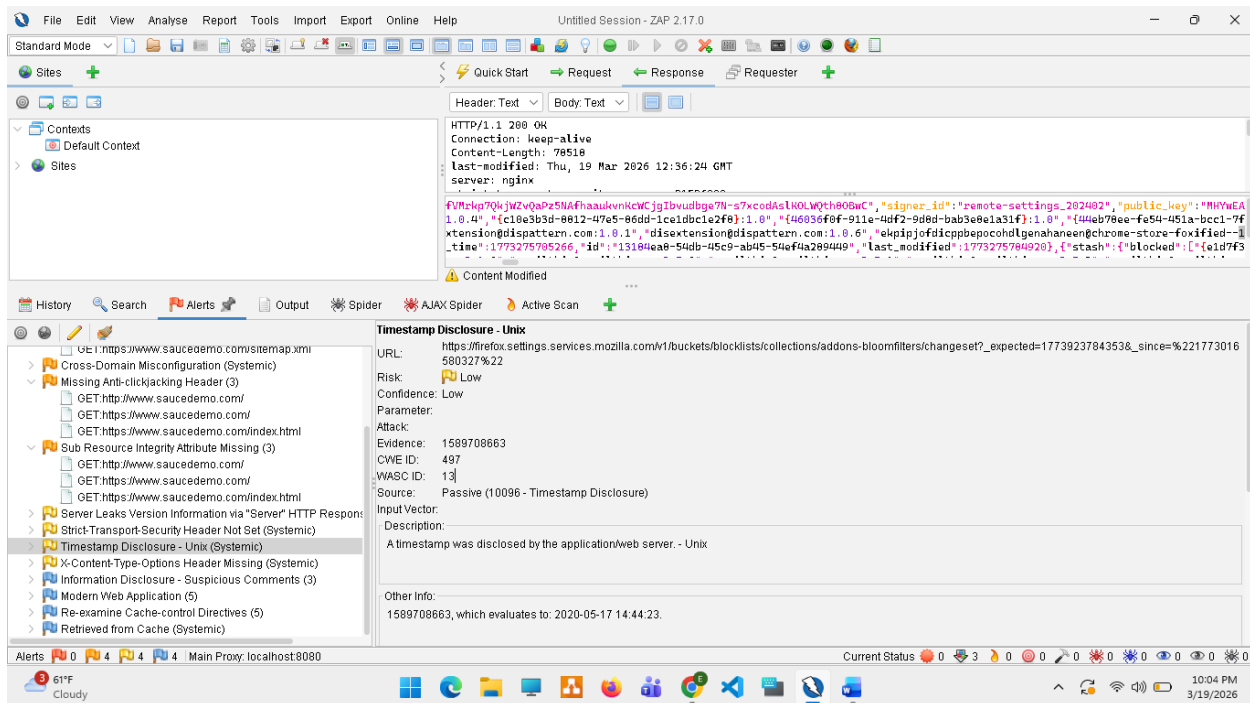
Finding L2: X-Content-Type-Options Header Missing

Field	Details
Risk Level	Low
Confidence	Medium
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://www.saucedemo.com/
Evidence	AmazonS3
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.



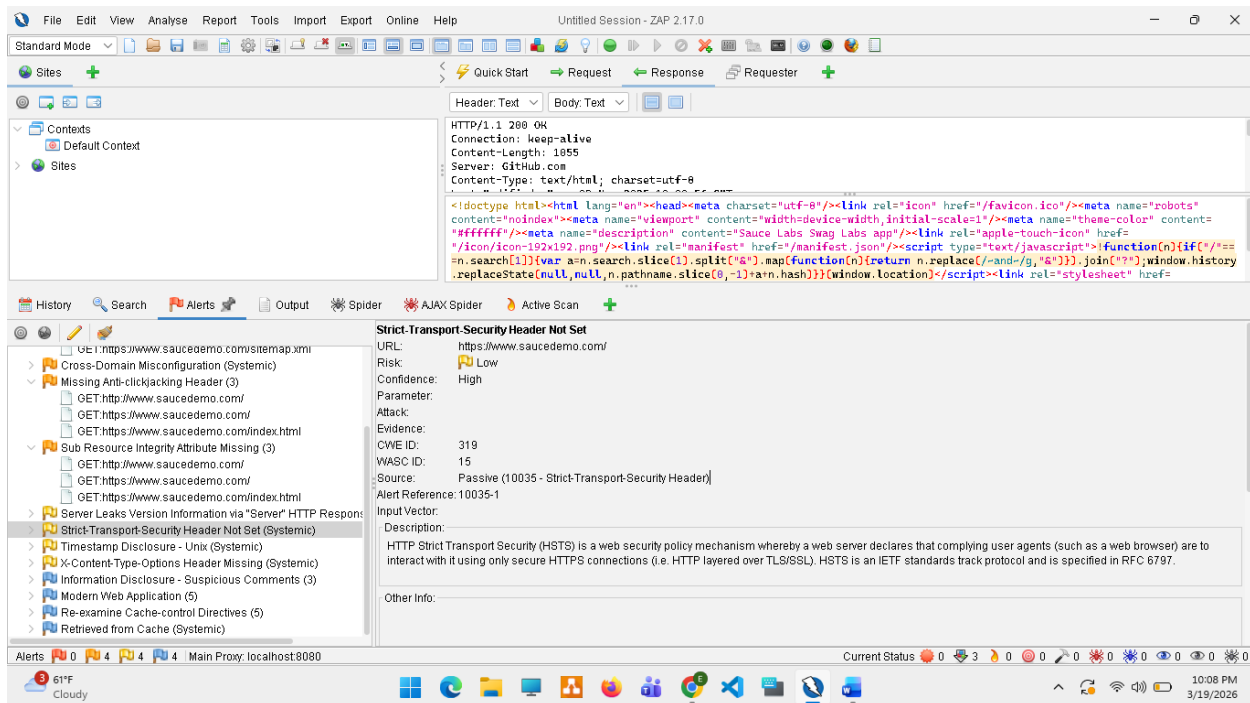
Finding L3: Timestamp Disclosure - Unix

Field	Details
Risk Level	Low
Confidence	Low
Description	A timestamp was disclosed by the application/web server. - Unix
URL	https://www.saucedemo.com/
Evidence	1589708663
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.



Finding L4: Strict-Transport-Security Header Not Set

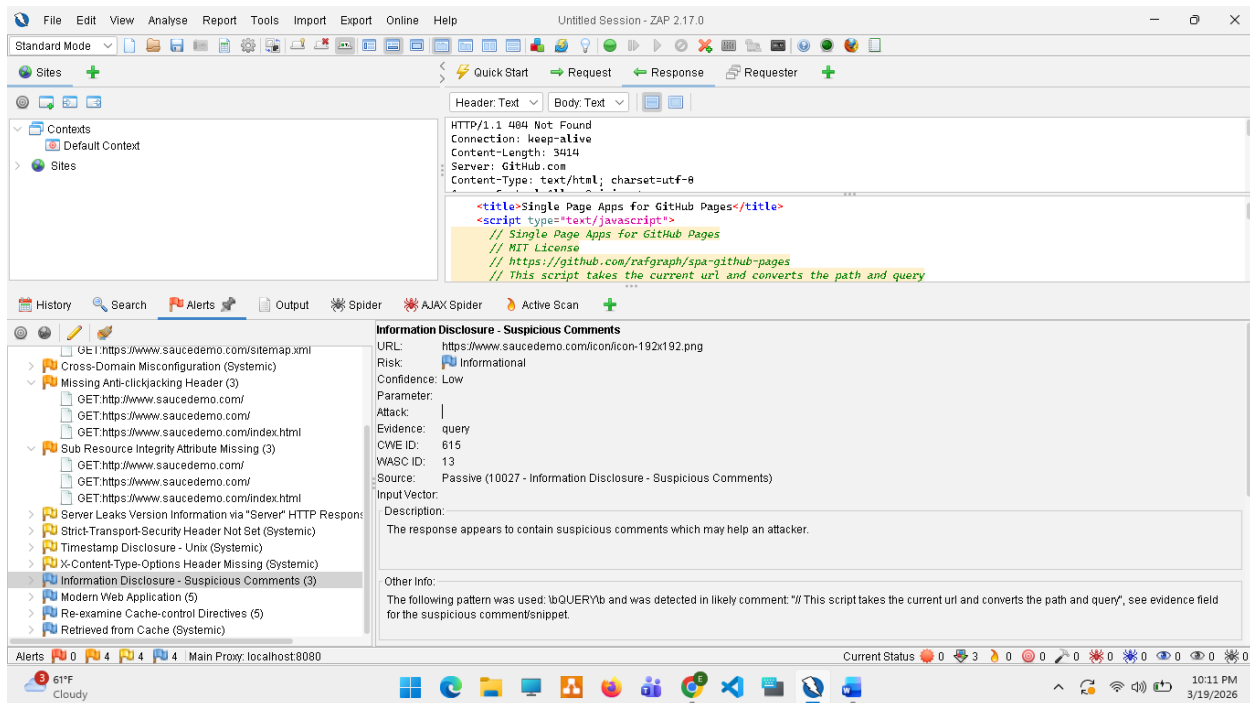
Field	Details
Risk Level	Low
Confidence	High
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://www.saucedemo.com/
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.



● INFORMATIONAL FINDINGS (4)

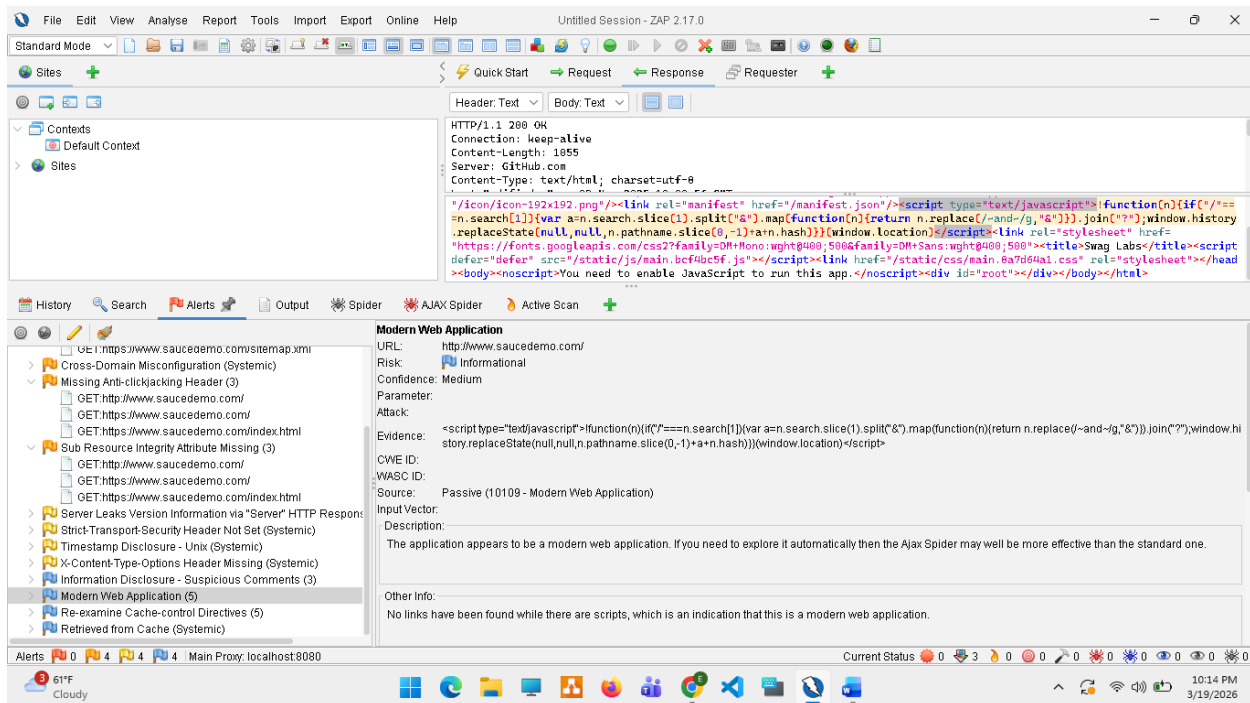
Finding I1: Information Disclosure - Suspicious Comments

Field	Details
Risk Level	Informational
Confidence	Low
Description	The response appears to contain suspicious comments which may help an attacker.
Evidence	query
URL	https://www.saucedemo.com/
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.



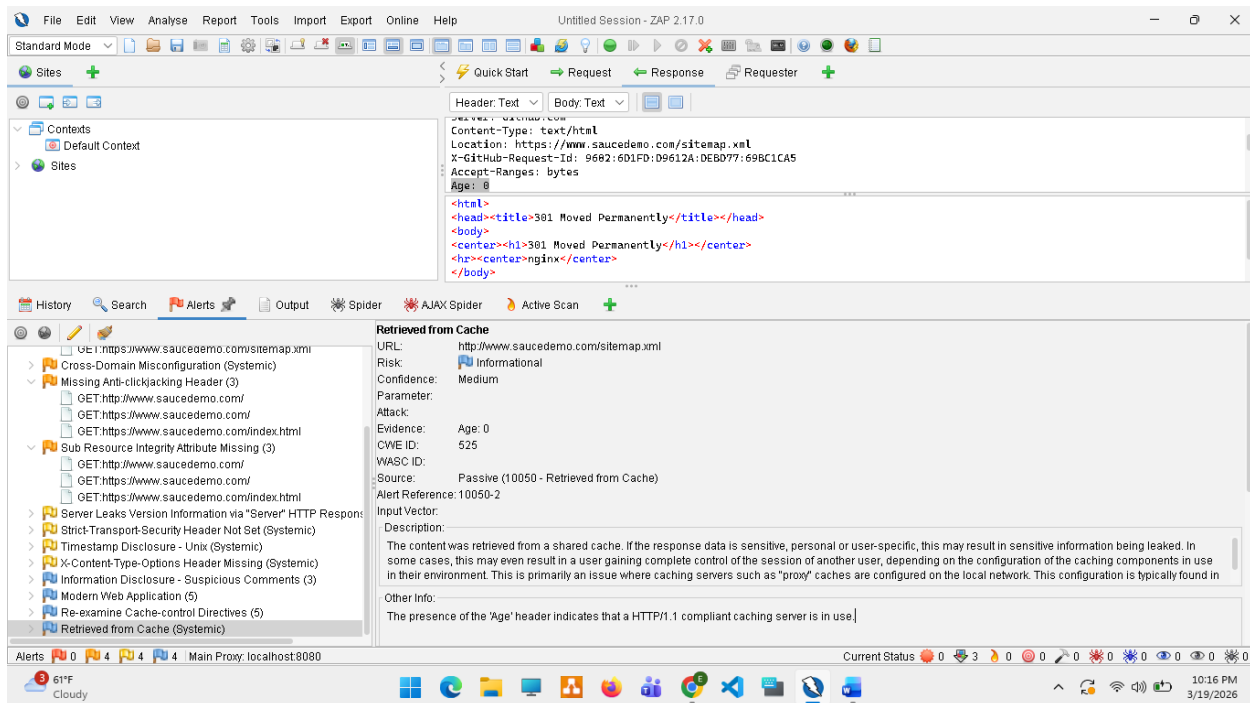
Finding I2: Modern Web Application

Field	Details
Risk Level	Informational
Confidence	Medium
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
Evidence	<script type="text/javascript">!function(n){if("/"===n.search[1]){var a=n.search.slice(1).split("&").map(function(n){return n.replace(/~/and~/g,"&")}).join("?");window.history.replaceState(null,null,n.pathname.slice(0,-1)+a+n.hash)}}(window.location)</script>
URL	https://www.saucedemo.com/
Solution	This is an informational alert and so no changes are required.



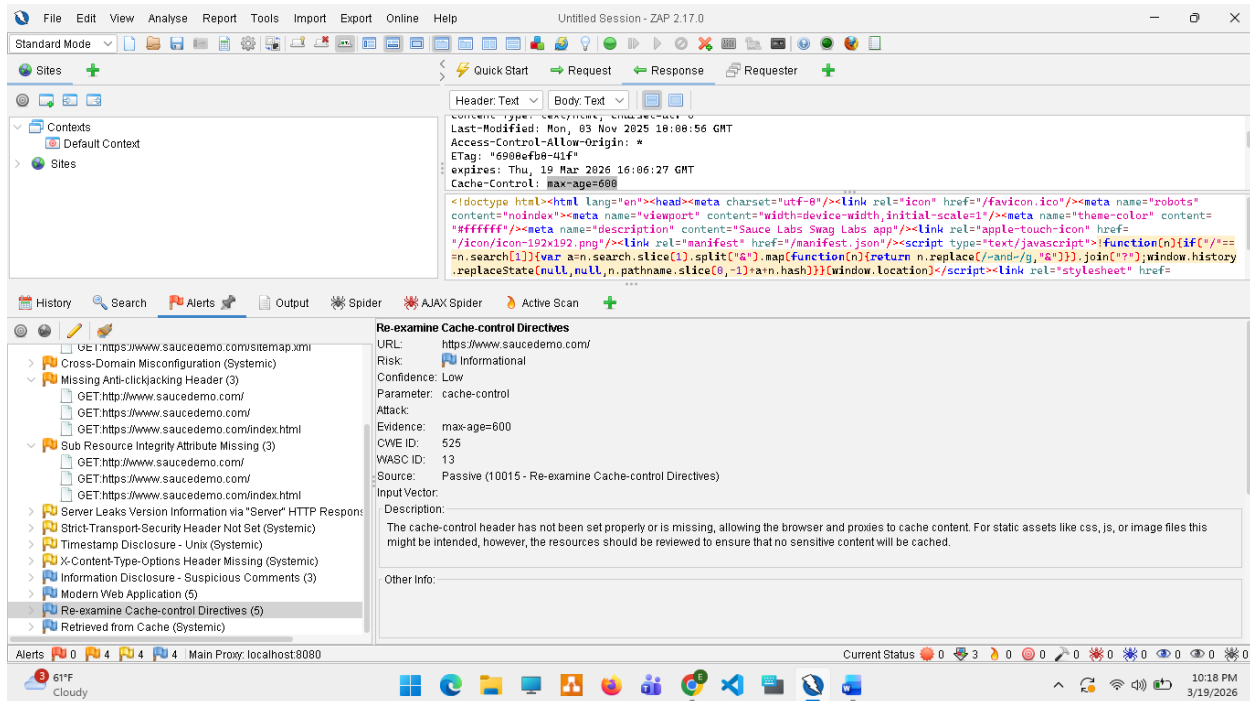
Finding I3: Retrieved from Cache

Field	Details
Risk Level	Informational
Confidence	Medium
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
Evidence	Age: 0
URL	https://www.saucedemo.com/
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.



Finding I4: Re-examine Cache-control Directives

Field	Details
Risk Level	Informational
Confidence	Low
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
Evidence	max-age=600
URL	https://www.saucedemo.com/
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".



Recommendations

1. Fix Medium Risk Issues First:

- Add CSP header
- Fix CORS misconfiguration (remove `Access-Control-Allow-Origin: \*`)
- Add X-Frame-Options header
- Add HSTS header

2. Address Low Risk Issues:

- Remove server version header
- Add X-Content-Type-Options
- Implement SRI for external resources
- Clean up code comments

3. Review of Informational Findings:

- Consider timestamp handling
- Review cache policies

